Informe técnico de investigación de incidente

Eventos: 715 · Hosts: 11 · Usuarios: 13 · Rango: 2026-10-23 07:46:07 → 2026-10-23 13:44:06 · Zona no indicada (timestamps sin offset) · Redacción: local

Riesgo global: Crítico (95/100)

Resumen técnico

Incidente INC-1 — IoCs: IPs ['10.10.1.14', '10.10.1.22', '10.10.1.31', '10.10.1.44', '10.10.2.15', '10.10.2.24', '10.10.3.18', '198.51.100.77', '203.0.113.74'], usuarios ['CORP\\admin', 'CORP\\aperez', 'CORP\\backupsvc', 'CORP\\dtorres', 'CORP\\helpdesk', 'CORP\\jlopez', 'CORP\\mgarcia', 'CORP\\mruiz', 'CORP\\rrojas', 'CORP\\slopez', 'CORP\\svc_backup'], hosts ['APP-SRV01', 'DB-SRV01', 'DC-01', 'DC01', 'FS-SRV01', 'WEB-01', 'WS-014', 'WS-018', 'WS-022', 'WS-023', 'WS-031'].
Hallazgos:
- F-01 [Alto] Password spraying desde 203.0.113.74 (T1110.003: Brute Force: Password Spraying (Credential Access)) — evidencia: EVT-00057, EVT-00058, EVT-00060, EVT-00061, EVT-00063, EVT-00065
- F-02 [Crítico] Inicio de sesión exitoso tras 33 fallos (203.0.113.74 → CORP\mgarcia@DC-01) (T1078: Valid Accounts (Initial Access/Persistence)) — evidencia: EVT-00057, EVT-00058, EVT-00060, EVT-00061, EVT-00063, EVT-00123
- F-03 [Crítico] Inicio de sesión exitoso tras 33 fallos (203.0.113.74 → CORP\mgarcia@WS-031) (T1078: Valid Accounts (Initial Access/Persistence)) — evidencia: EVT-00057, EVT-00058, EVT-00060, EVT-00061, EVT-00063, EVT-00126
- F-04 [Medio] Comando ofuscado (Base64) en APP-SRV01 (T1027: Obfuscated Files or Information (Defense Evasion)) — evidencia: EVT-00198
- F-05 [Medio] Comando ofuscado (Base64) en WS-023 (T1027: Obfuscated Files or Information (Defense Evasion)) — evidencia: EVT-00280
- F-06 [Alto] Posible movimiento lateral de CORP\aperez (7 hosts en 30 min) (T1021: Remote Services (Lateral Movement)) — evidencia: EVT-00027, EVT-00039, EVT-00044, EVT-00053, EVT-00054, EVT-00055
- F-07 [Alto] Posible movimiento lateral de CORP\backupsvc (3 hosts en 30 min) (T1021: Remote Services (Lateral Movement)) — evidencia: EVT-00019, EVT-00030, EVT-00038, EVT-00042
- F-08 [Alto] Posible movimiento lateral de CORP\dtorres (3 hosts en 30 min) (T1021: Remote Services (Lateral Movement)) — evidencia: EVT-00004, EVT-00031, EVT-00034, EVT-00041
- F-09 [Alto] Posible movimiento lateral de CORP\helpdesk (4 hosts en 30 min) (T1021: Remote Services (Lateral Movement)) — evidencia: EVT-00001, EVT-00016, EVT-00021, EVT-00028, EVT-00035
- F-10 [Alto] Posible movimiento lateral de CORP\jlopez (5 hosts en 30 min) (T1021: Remote Services (Lateral Movement)) — evidencia: EVT-00003, EVT-00012, EVT-00018, EVT-00023, EVT-00025, EVT-00026
- F-11 [Alto] Posible movimiento lateral de CORP\mgarcia (3 hosts en 30 min) (T1021: Remote Services (Lateral Movement)) — evidencia: EVT-00006, EVT-00022, EVT-00024
- F-12 [Alto] Posible movimiento lateral de CORP\mruiz (3 hosts en 30 min) (T1021: Remote Services (Lateral Movement)) — evidencia: EVT-00124, EVT-00136, EVT-00141, EVT-00144, EVT-00151, EVT-00196
- F-13 [Alto] Posible movimiento lateral de CORP\rrojas (5 hosts en 30 min) (T1021: Remote Services (Lateral Movement)) — evidencia: EVT-00007, EVT-00008, EVT-00009, EVT-00014, EVT-00017, EVT-00036
- F-14 [Alto] Posible movimiento lateral de CORP\slopez (4 hosts en 30 min) (T1021: Remote Services (Lateral Movement)) — evidencia: EVT-00011, EVT-00013, EVT-00015, EVT-00020, EVT-00037, EVT-00040
- F-15 [Alto] Posible movimiento lateral de CORP\svc_backup (3 hosts en 30 min) (T1021: Remote Services (Lateral Movement)) — evidencia: EVT-00125, EVT-00132, EVT-00134, EVT-00164, EVT-00173, EVT-00177

Razonamiento (CoT)

• F-01: 1) Origen 203.0.113.74: interna. 2) 33 fallos contra 8 usuario(s); ≥5 en ≤10 min => anomalía de volumen. 3) Sin ofuscación aplicable. 4) Riesgo por volumen + exposición del origen.

• F-02: 1) Éxito de CORP\mgarcia desde 203.0.113.74 posterior a la ráfaga de fallos. 2) Patrón consistente con credencial adivinada. 3) Requiere validar si el usuario reconoce la sesión.

• F-03: 1) Éxito de CORP\mgarcia desde 203.0.113.74 posterior a la ráfaga de fallos. 2) Patrón consistente con credencial adivinada. 3) Requiere validar si el usuario reconoce la sesión.

• F-04: 1) Se inspecciona Process_CommandLine sin ejecutarlo ni decodificarlo. 2) Indicadores: Comando ofuscado (Base64). 3) Ofuscación/descarga => alta probabilidad de abuso.

• F-05: 1) Se inspecciona Process_CommandLine sin ejecutarlo ni decodificarlo. 2) Indicadores: Comando ofuscado (Base64). 3) Ofuscación/descarga => alta probabilidad de abuso.

• F-06: 1) Mismo usuario autentica en varios hosts. 2) ≥3 hosts en 30 min no es normal para un usuario humano. 3) Verificar si es una cuenta de servicio.

• F-07: 1) Mismo usuario autentica en varios hosts. 2) ≥3 hosts en 30 min no es normal para un usuario humano. 3) Verificar si es una cuenta de servicio.

• F-08: 1) Mismo usuario autentica en varios hosts. 2) ≥3 hosts en 30 min no es normal para un usuario humano. 3) Verificar si es una cuenta de servicio.

• F-09: 1) Mismo usuario autentica en varios hosts. 2) ≥3 hosts en 30 min no es normal para un usuario humano. 3) Verificar si es una cuenta de servicio.

• F-10: 1) Mismo usuario autentica en varios hosts. 2) ≥3 hosts en 30 min no es normal para un usuario humano. 3) Verificar si es una cuenta de servicio.

• F-11: 1) Mismo usuario autentica en varios hosts. 2) ≥3 hosts en 30 min no es normal para un usuario humano. 3) Verificar si es una cuenta de servicio.

• F-12: 1) Mismo usuario autentica en varios hosts. 2) ≥3 hosts en 30 min no es normal para un usuario humano. 3) Verificar si es una cuenta de servicio.

• F-13: 1) Mismo usuario autentica en varios hosts. 2) ≥3 hosts en 30 min no es normal para un usuario humano. 3) Verificar si es una cuenta de servicio.

• F-14: 1) Mismo usuario autentica en varios hosts. 2) ≥3 hosts en 30 min no es normal para un usuario humano. 3) Verificar si es una cuenta de servicio.

• F-15: 1) Mismo usuario autentica en varios hosts. 2) ≥3 hosts en 30 min no es normal para un usuario humano. 3) Verificar si es una cuenta de servicio.

Hallazgos y evidencia

ID	Riesgo	Hallazgo	MITRE	Evidencia (Log_ID)
F-01	Alto	Password spraying desde 203.0.113.74	T1110.003	EVT-00057, EVT-00058, EVT-00060, EVT-00061, EVT-00063, EVT-00065, EVT-00066, EVT-00068
F-02	Crítico	Inicio de sesión exitoso tras 33 fallos (203.0.113.74 → CORP\mgarcia@DC-01)	T1078	EVT-00057, EVT-00058, EVT-00060, EVT-00061, EVT-00063, EVT-00123
F-03	Crítico	Inicio de sesión exitoso tras 33 fallos (203.0.113.74 → CORP\mgarcia@WS-031)	T1078	EVT-00057, EVT-00058, EVT-00060, EVT-00061, EVT-00063, EVT-00126
F-04	Medio	Comando ofuscado (Base64) en APP-SRV01	T1027	EVT-00198
F-05	Medio	Comando ofuscado (Base64) en WS-023	T1027	EVT-00280

ID	Riesgo	Hallazgo	MITRE	Evidencia (Log_ID)
F-06	Alto	Posible movimiento lateral de CORP\aperez (7 hosts en 30 min)	T1021	EVT-00027, EVT-00039, EVT-00044, EVT-00053, EVT-00054, EVT-00055, EVT-00095, EVT-00106
F-07	Alto	Posible movimiento lateral de CORP\backupsvc (3 hosts en 30 min)	T1021	EVT-00019, EVT-00030, EVT-00038, EVT-00042
F-08	Alto	Posible movimiento lateral de CORP\dtorres (3 hosts en 30 min)	T1021	EVT-00004, EVT-00031, EVT-00034, EVT-00041
F-09	Alto	Posible movimiento lateral de CORP\helpdesk (4 hosts en 30 min)	T1021	EVT-00001, EVT-00016, EVT-00021, EVT-00028, EVT-00035
F-10	Alto	Posible movimiento lateral de CORP\jlopez (5 hosts en 30 min)	T1021	EVT-00003, EVT-00012, EVT-00018, EVT-00023, EVT-00025, EVT-00026, EVT-00029, EVT-00032
F-11	Alto	Posible movimiento lateral de CORP\mgarcia (3 hosts en 30 min)	T1021	EVT-00006, EVT-00022, EVT-00024
F-12	Alto	Posible movimiento lateral de CORP\mruiz (3 hosts en 30 min)	T1021	EVT-00124, EVT-00136, EVT-00141, EVT-00144, EVT-00151, EVT-00196
F-13	Alto	Posible movimiento lateral de CORP\rrojas (5 hosts en 30 min)	T1021	EVT-00007, EVT-00008, EVT-00009, EVT-00014, EVT-00017, EVT-00036, EVT-00043
F-14	Alto	Posible movimiento lateral de CORP\slopez (4 hosts en 30 min)	T1021	EVT-00011, EVT-00013, EVT-00015, EVT-00020, EVT-00037, EVT-00040
F-15	Alto	Posible movimiento lateral de CORP\svc_backup (3 hosts en 30 min)	T1021	EVT-00125, EVT-00132, EVT-00134, EVT-00164, EVT-00173, EVT-00177

Recomendaciones (NIST SP 800-61)

• Contención: aislar los hosts APP-SRV01, DB-SRV01, DC-01, DC01, FS-SRV01, WEB-01, WS-014, WS-018, WS-022, WS-023, WS-031 y bloquear IPs externas 10.10.1.14, 10.10.1.22, 10.10.1.31, 10.10.1.44, 10.10.2.15, 10.10.2.24, 10.10.3.18, 198.51.100.77, 203.0.113.74.

• Contención: deshabilitar y restablecer credenciales de CORP\admin, CORP\aperez, CORP\backupsvc, CORP\dtorres, CORP\helpdesk, CORP\jlopez, CORP\mgarcia, CORP\mruiz, CORP\rrojas, CORP\slopez, CORP\svc_backup.

• Erradicación: revisar persistencia (cuentas nuevas, tareas programadas) en los hosts listados.

• Recuperación: restaurar desde estado conocido y monitorear 30 días.

• Post-incidente: lecciones aprendidas y ajuste de reglas SIEM (NIST SP 800-61).

Limitaciones

• Zona no indicada (timestamps sin offset)

• Alertas deterministas = hipótesis, no incidentes confirmados.

• IA no disponible (BadRequestError); se usó redactor local.